

LKT MCP boundary review — public sample

Frozen: 2026-09-12

Repository revision: e750e5ae24b780e45de896f7dc3a769d2410dabd

Decision

GO for local, read-only use in the recorded scope. The inspected server exposes exactly two read-only tools and one status resource. Protocol calls completed against a project-owned multilingual fixture, the database modification timestamp did not change, and all 14 focused tests passed.

NO-GO for direct remote exposure. The standalone HTTP bridge has no client authentication. It correctly refuses non-loopback binding, but loopback is not an authorization system. Any connected client can receive returned excerpts and may send them beyond the device.

Inspected surface

- `query_private_knowledge`: bounded multilingual search over accepted knowledge.
- `trace_private_claim`: resolves a returned claim or evidence identifier.
- `lkt://collections/status`: bounded counts, languages, opaque collection IDs, and hashes.
- No prompts, ingestion tools, model calls, SQL tools, write tools, delete tools, or configuration tools are advertised.

Controls observed

- Both tools advertise `readOnlyHint=true`, `destructiveHint=false`, `idempotentHint=true`, and `openWorldHint=false`.
- SQLite opens with `mode=ro` and `PRAGMA query_only=ON`.
- Queries, results, graph depth, nodes, claims, evidence, excerpts, collections, and SQL work are bounded.
- Rejected, archived, model-basis, ungrounded, and unsafe-locator cases have focused regression tests.
- Non-loopback HTTP binding is refused.

Evidence executed

The official Python MCP SDK 2.2.0 listed the tool/resource surface and called both tools. The query 春 returned one accepted multilingual result; its claim was traced to one project-owned excerpt and a validated source hash. The status resource reported English, Japanese, and Chinese while withholding the database path.

Residual risks and required decisions

1. A read-only server can still disclose data to an authorized or compromised client.
2. Tool annotations are advisory; the SQLite boundary and response filtering are the stronger controls here.
3. Loopback HTTP requires a separately designed authenticated, encrypted gateway before remote use.
4. Returned excerpts must not contain credentials or material the operator is not permitted to disclose.
5. This is a code-and-protocol boundary review, not a penetration test, security certification, or guarantee of fitness for production.

Packet contents

The packet includes the protocol inventory, project-owned query/trace/status outputs, environment versions, focused test log, inspected-source hashes, this report, a summary, and a manifest. It contains no customer data, browser session, credential, model weight, private book, or production database.